



Best Practices for Secure Adoption and Use of Agentic AI

Special Interest Group



ISACA®

Sydney Chapter



Best Practices for Secure Adoption and Use of Agentic AI

SIG Stream 01: Innovation and Secure By Design

Authors (SIG Stream 01)

Wilson Chiu
Krishna Bagla
Patrick Meek
Narayana Madineni
Gaurav Vikash
Aman Deep
Kush Sharma
Denny Wan (Member and In Memory Of)

Peer Reviewers (SIG Stream 02)

Varun Pant
Suzanne Theron
George Sarandrea
Emile Ghadiminejad
Asaf Ahmad

Industry Reviewers:

Bharat Bajaj (ISACA Melbourne Chapter)
Kavita Chetty (ISACA Auckland Chapter)
Manpreet Singh
Maryam Shoraka

This initiative was run under the auspices of ISACA Leadership Team:

Chirag Joshi (President, ISACA Sydney Chapter, 2025)
Muralee Krishnan (Coordinator, SIG 2)
Shalbin Samuel (Coordinator, SIG 1)

Table of Contents

ABSTRACT	3
Executive Summary	3
1. Introduction	6
2. Scope	7
2.1 Systems in Scope	7
2.2 Business Contexts	7
2.3 Lifecycle and Boundary Considerations	8
2.4 Out of Scope	8
3. Principles	9
4. Assets	10
4.1 Infrastructure Assets	11
4.2 Orchestration Assets	12
4.3 Data and Decision Assets	12
4.4 Tool Assets	13
5. Threat Landscape	14
5.1 Input Compromise	15
5.2 Agent Compromise	16
5.3 Multi-Agent Environment Exploitation	17
5.4 Communication Manipulation	17
5.5 Identity and Privileged Access Abuse	18
6. Security Controls	19
6.1 Governance Controls	20
6.2 Technical Controls	21
6.3 Assurance Controls	22
7. Target State for Secure Agentic AI	23
7.1 Target Architecture Overview	23
7.2 Benefits of the proposed architecture	25
8. Agentic AI Security Maturity Model	27
8.1 Level 1: Initial	28
8.2 Level 2: Managed	29
8.3 Level 3: Defined	29
8.4 Level 4: Quantitatively Managed	30
8.5 Level 5: Optimising	30
8.6 Measurable Metrics	31
9. Operationalising the Framework	32
9.1 Immediate Implementation Priorities	33
9.2 Secure High-Value Integration Points	34
9.3 Anticipate and Address Key Challenges	34
9.4 Agree on Cross-Functional Responsibilities	34
10. Conclusion and Strategic Imperatives	35
Glossary	36
References	38

ABSTRACT

Agentic AI can perceive, reason, plan, act, delegate, learn and coordinate tasks autonomously using one or more agents to achieve complex goals, offering new opportunities. As enterprises deploy agentic AI use cases from experimentation into production, they face new security challenges with an extended attack surface. For Risk, Security and Data Professionals (e.g. CISO, Security Architects, Security Engineers, Risk and Assurance Managers, Data Governance experts and other specialised functions), Agentic AI risks are increasingly prevalent when assessing risk arising from malicious inputs, compromised components, and the propagation of authority, identity, and context across distributed agents. Traditional security controls are not well equipped to prevent these cascading risks. This paper presents a threat-informed risk-based framework for securing agentic AI. It also introduces a maturity model to help organisations benchmark posture, prioritise safeguards, and scale controls ensuring agentic AI operates with accountable, trustworthy, and governed autonomy. It prescribes practical steps that organisations can take to integrate agentic AI into critical workflows using a security framework built on strong foundational principles.

Executive Summary

Agentic AI represents a transformative shift in artificial intelligence, moving from static workflows to ecosystems of autonomous agents capable of real-time coordination and decision-making. These systems offer significant operational advantages and enhance scalability, responsiveness, and efficiency. It also introduces a new security challenge that traditional controls are not equipped to manage.

This paper presents a comprehensive framework for securing agentic AI deployments, particularly in multi-agent environments where autonomous behaviour intersects with business-critical operations. It outlines guiding principles, threat categories, control strategies, and a maturity model to help organisations adopt agentic AI responsibly and securely.

Agentic systems are increasingly deployed in business processes such as customer service orchestration, supply chain automation, and autonomous development operations. Their ability to adapt roles, invoke tools, and share context across distributed environments introduces risks that are systemic, fast-moving, and difficult to detect without purpose-built safeguards. The framework is anchored in four foundational principles: observability, bounded autonomy, ephemeral identity, and coordination trust. These principles enable organisations to maintain visibility, control, and trust in highly dynamic environments.

The paper identifies five key threat categories: input compromise, agent compromise, multi-agent exploitation, communication manipulation, and identity abuse. These threats are illustrated with real-world examples, such as prompt injection attacks, compromised coordination protocols, and impersonation via stale credentials. Each threat type is mapped to specific asset categories—Infrastructure, Orchestration, Data & Decision, and Tools, ensuring that security measures are targeted and effective.

Security controls are categorised into governance, technical, and assurance domains. Governance measures include role definitions, delegation rules, and escalation pathways. Technical controls span memory isolation, signed communications, toolchain attestation, and real-time policy enforcement. Assurance mechanisms provide telemetry pipelines, anomaly detection, cryptographically verifiable logs, and behavioural drift monitoring. Together, these controls form a layered defence architecture that protects agentic AI systems across their lifecycle.

A five-level maturity model guides organisations from unmanaged experimentation to fully verified coordination. Progression involves embedding runtime enforcement, observability, and trust mechanisms into live operations. Metrics such as agent registration rates, signed

communication coverage, and anomaly response times help benchmark progress and inform strategic planning.

To operationalise the framework, organisations should inventory agentic deployments, assign cross-functional ownership, and prioritise observability and ephemeral identity in high-impact use cases. Securing orchestration layers, tool brokers, shared memory systems, and communication channels is critical. Controls must be integrated into CI/CD pipelines and governance structures to ensure continuous alignment with business risk appetite.

Security must be embedded into the coordination layer itself shaping how agents plan, delegate, and negotiate. This transforms security from a reactive constraint into a proactive enabler of safe autonomy. Organisations that act now embedding observability, bounded autonomy, and trust-preserving mechanisms will be positioned to scale agentic AI with confidence, resilience, and accountability.

1. Introduction

Agentic AI systems represent a decisive shift in how intelligent systems operate. Instead of executing within fixed, predictable workflows, they comprise autonomous AI agents that coordinate, delegate, and adapt their behaviour in real time. They negotiate roles, sequence tool calling, and adjust plans dynamically in pursuit of evolving objectives. This agility delivers capabilities far beyond static systems, but also redefines the security problem.

In a multi agent agentic AI ecosystem, authority can transfer mid-execution, decisions can cascade through multi-step delegation chains, and context can be shared or altered across distributed components. Examples of these agentic AI agents are expanding in financial and legal industries, where agents are transacting on behalf of customers and at the same time aiding legal practitioners in simplifying legal documentation. A single compromised agent can alter shared memory, mislead peers, or take control of downstream actions rapidly affecting the entire system. These behaviours break the assumptions that underpin traditional AI security, such as predictable execution flow, fixed trust boundaries, and static identity assignments.

Securing such environments requires a security architecture built on four foundational principles:

- **Observability:** every action, decision, and coordination event is captured, attributable, and reviewable in real time.
- **Bounded autonomy:** agents operate only within defined, revocable scopes tied to their role and context.
- **Ephemeral identity:** no credential, key, or access token persists beyond its intended purpose or session.
- **Preserve coordination trust:** inter-agent communication and shared memory remain authentic, verified, and resistant to manipulation.

These principles enable organisations to maintain visibility, control, and trust in highly dynamic, distributed environments. They underpin the threat model, control framework, and maturity pathway presented in this paper providing a clear foundation for both strategic planning and practical implementation.

2. Scope

This paper addresses the security of agentic AI systems where autonomous decision-making, inter-agent coordination, and dynamic tool use have material impact on business operations, safety, compliance, or trust. The focus is on deployments in which multiple agents operate within a shared environment, making delegated decisions, invoking tools, and exchanging information across interconnected orchestration layers and communication channels.

2.1 Systems in Scope

The guidance applies to agentic AI systems that exhibit any of the following characteristics:

- **Multi-agent coordination:** agents collaborate, negotiate, or divide tasks dynamically to achieve objectives.
- **Adaptive role behaviour:** agent roles, authorities, and capabilities can change at runtime.
- **Delegated decision-making:** agents conduct activities based on their assigned objectives without constant human oversight. The output from one agent may form the input of another agent, or part of the overall objective of the entire AI environment.
- **Dynamic tool and system access:** agents invoke APIs to interact with Model Context Protocol (MCP) servers, tools, or services on demand, with varying scopes and permissions. In particular, MCP servers are becoming a standard and help Agentic AI applications connect to external data sources and services to extend their capabilities..
- **Shared environments:** agents read from and write to common memory, vector stores, knowledge graphs, and are operating in a shared infrastructure environment.

2.2 Business Contexts

The practices apply to various business use cases. Here are some examples:

- **Business process orchestration:** AI-driven coordination of workflows, task assignments, and operational decisions.
- **Decision automation in regulated or safety-critical environments:** financial services, healthcare, transportation, defence.
- **Customer-facing services:** multi-agent chatbots, digital assistants, and service orchestration platforms.
- **Enterprise operations and supply chains:** dynamic resource allocation, procurement automation, logistics coordination.

- **AI-enhanced development and operations:** autonomous agents for code generation, deployment orchestration, security operations, or monitoring.

2.3 Lifecycle and Boundary Considerations

Security risks in agentic AI should be considered across the full lifecycle from initial design through live operations and post-deployment assurance:

- **Design phase:** establish role definitions, trust boundaries, and governance requirements before deployment.
- **Pre-deployment:** validate role and tool configurations, delegation rules, and baseline telemetry in controlled environments.
- **Runtime:** enforce policy, monitor behaviour, prompts, outputs and detect drift or anomalies in real time.
- **Post deployment:** continuous monitoring, safety guardrails, feedback loops, performance tracking, risk assessments, governance compliance, configuration management, and user training.

Boundaries for this framework extend beyond the individual agent to the system-of-agents and the enabling infrastructure, including orchestration layers, shared memory, tool brokers, and inter-agent communication channels.

2.4 Out of Scope

This framework does not address airgapped experimental environments, AI services with no coordinated agentic behaviour and AI model security concerns such as model inversion or training data poisoning associated with an individual model.

3. Principles

Agentic AI introduces a structurally novel threat profile driven by distributed autonomy, mutable role dynamics, and asynchronous coordination. Agentic AI deployments rely on dynamic reasoning, shared context, and runtime delegation expanding the adversarial surface in both depth and volatility.

The proposed framework is built on 4 guiding core principles shown in the below table in the context of a secure agentic AI deployment with multiple agents working together.

Principle	Target State Description
Observability	All agent activity - delegations, tool invocations, memory changes, and coordination events - is captured in structured, queryable telemetry for real-time oversight and post-event analysis.
Bounded autonomy	Agents operate only within defined, enforceable scopes of action tied to role, context, and delegated authority. Execution boundaries can be adapted or revoked at runtime, preventing ungoverned behaviour.
Ephemeral identity	Identities, credentials, and privileges are issued for limited durations and bound to specific runtime contexts. Expiry and revocation occur automatically to limit persistence and reduce lateral movement.
Preserve coordination trust	Inter-agent communication and shared memory are authenticated, signed, and resistant to manipulation, disruption, or replay. Coordination pathways are monitored for behavioural drift and trust degradation.

Table 1 Core principles governing the proposed security framework for Agentic AI systems

Although these principles are designed for agentic AI, agents can be seen as another digital employee carrying out tasks that were assigned. From a practice implication perspective these are similar to day-to-day security practices.

- Observability - user logging and monitoring.
- Bounded autonomy - role based access control.
- Ephemeral identity - identity and privileged access management.
- Preserve coordination trust - fraud and user behavioural analytics.

4. Assets

Agentic AI systems operate through a layered set of interdependent assets that enable autonomy, coordination, and execution. Assets enable agentic functionality and serve as an attack surface for threat actors. Unlike traditional AI systems with fixed models and bounded inputs, agentic deployments involve mutable state, dynamic delegation, and real-time interactions across multiple agents and system boundaries.

The table below shows four asset types, their purposes, examples, and the foundational principles that apply to each:

Asset Type	Purpose	Principles	Examples
Infrastructure	The shared infrastructure and coordination layer used by agents to communicate, share information, and identify each other	● Preserve coordination trust ● Observability ● Ephemeral identity	Coordination protocols, shared memory spaces, communication channels, ephemeral identities
Orchestration	The decision-making and orchestration components used by agents to plan, execute, and stay within defined limits	● Bounded autonomy ● Observability ● Preserve coordination trust	Orchestration logic, agent controllers, planner modules, policy enforcement points
Data and Decision	The knowledge, context, and rules used by agents understand their roles, make decisions, and take actions	● Preserve coordination trust ● Observability	Prompts, memories, plans, policies, role configurations, agent context
Tools	The tools and execution components agents used to carry out actions and interact with different environments	● Bounded autonomy ● Ephemeral identity	Retrieval Augmented Generation, tools, API connectors, task handlers, toolchain plugins

Table 2 Asset categories of Agentic AI systems

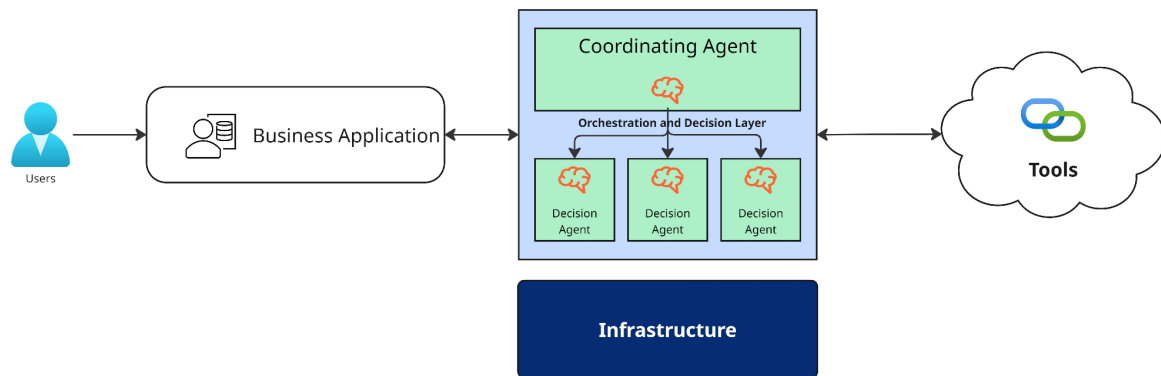


Diagram 1 depicting how the four assets type work together

4.1 Infrastructure Assets

Infrastructure assets underpin the distributed nature of agentic AI, enabling communication, coordination, and identity propagation across agents and contexts. They include:

- **Coordination Protocols:** Structured messaging standards and operational semantics that govern how agents communicate and synchronise.
- **Shared Memory Spaces:** Common repositories where multiple agents read from or write to for collaborative decision-making or state persistence.
- **Communication Channels:** Transport layers for agent-to-agent or agent-to-orchestrator messaging, often implemented via HTTP, message queues, or custom protocols.
- **Ephemeral Identities and Credentials:** Short-lived authentication and authorisation tokens that enable scoped access to tools, memory, or external systems.
- **Shared IT infrastructure:** On-Prem/Cloud Infrastructure where agents run.

4.2 Orchestration Assets

Orchestration assets govern the logic, sequencing, and constraints of agentic behaviour. They determine how plans are executed, decisions are evaluated, and agent operations are bounded. Key elements include:

- **Orchestration Logic:** The rules and coordination flows that determine task distribution, agent invocation, and completion validation.
- **Planner Modules:** Components that generate, revise, and evaluate action plans based on current goals, constraints, and feedback.
- **Agent Controllers:** Modules responsible for initialising, supervising, and terminating agent processes.
- **Policy Enforcement Points:** Embedded or external mechanisms that enforce runtime constraints, prevent escalation, and detect non-compliant behaviours.

4.3 Data and Decision Assets

Data and Decision assets comprise the dynamic knowledge base that agents use to reason, plan, and contextualise actions. As cognitive substrate of agentic systems, they are frequently read from, written to, or synthesised by agents during operation and include:

- **Prompts and Instruction Sets:** The initial and evolving guidance that defines an agent's behaviour, role, and constraints.
- **Memories:** Short-term (session context) and long-term (persistent knowledge) internal representations to store observations, prior decisions, and tool interactions.
- **Goals and Subgoals:** Structured task representations and decompositions that govern the agent's execution logic.
- **Policies and Role Configurations:** Embedded or externally referenced behavioural boundaries, permissions, or constraints.
- **Agent Context:** The current state and operational metadata influencing the agent's interpretation of inputs and decisions.

4.4 Tool Assets

Tool assets are the executable components through which agents interact with their environment, perform computations, and carry out delegated tasks. These include:

- **Tools and API Connectors:** External systems callable by agents for specific operations (e.g., databases, cloud functions, automation workflows).
- **Task Handlers and Action Executors:** Internal modules responsible for processing commands and triggering system-level behaviours.
- **Toolchain Plugins:** Modular components that augment agent capabilities, often linked via frameworks enabling tool discovery and invocation.
- **Retrieval Augmented Generation (RAG):** Reference to external data source or reference data or vector databases.

5. Threat Landscape

Threats are categorised into 5 groups to help prescribe targeted, measurable and integrated controls in the proposed framework as shown in the below table.

Threat Category	Summary	Targeted Assets	Principles at Risk
Input Compromise	Malicious or corrupted inputs distort agent reasoning, planning, or decision-making	Data and Decision, Tools	Observability, Preserve coordination trust
Agent Compromise	An agent's goals, code, or control logic are altered to produce unsafe or unauthorised actions	Orchestration, Tools	Bounded autonomy, Ephemeral identity, Observability
Multi-Agent Environment Exploitation	Exploiting shared infrastructure or interdependent systems to bypass safeguards or disrupt operations	Infrastructure, Orchestration, Data and Decision	Preserve coordination trust, Observability, Bounded autonomy
Communication Manipulation	Targeting inter-agent communication channels to distort coordination or inject malicious influence	Infrastructure, Data and Decision	Preserve coordination trust, Observability
Identity and Privileged Access Abuse	Exploiting weaknesses in identity lifecycle or privilege controls to impersonate or escalate access	Infrastructure, Tools, Orchestration	Ephemeral identity, Bounded autonomy, Preserve coordination trust

Table 3: Threat categories affecting Agentic AI systems

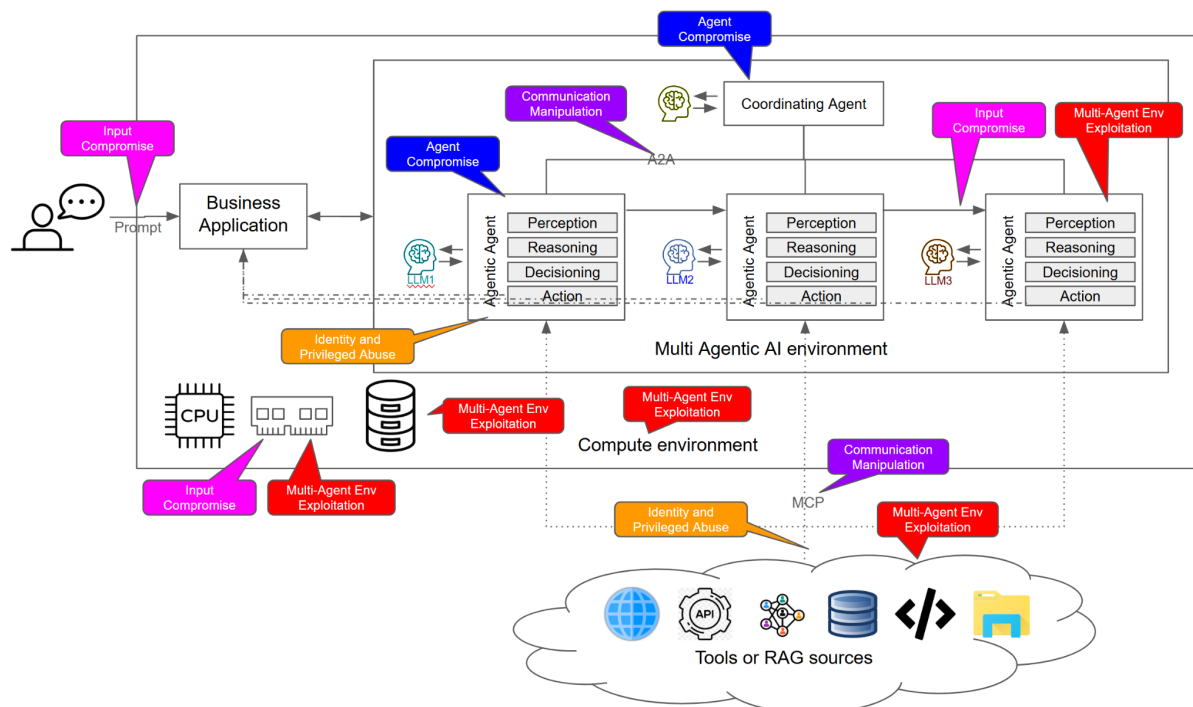


Diagram 2 depicting threats to various components of the Multi Agent AI environment.

5.1 Input Compromise

Malicious or corrupted inputs distort agent reasoning, planning, or decision-making.

- Injection of falsified or adversarial content into shared memory or vector stores, leading downstream agents to act on malicious context.
- Cascading misinformation amplified by multiple agents and reinforced through shared state.
- Prompt or command injection via task inputs, enabling unauthorised tool execution or policy circumvention. For example, [Researchers at Hidden Layer developed a prompt injection technique that bypasses security guardrails \(Reference 16\)](#) and results in AI models providing prohibited outputs.
- Malicious input to compromise target agent and downstream agents that rely on its output. For example, [Upworthy shared a story on how a hacker tricked chatbot to agree to sell him a \\$76000 vehicle for \\$1 using a manipulative prompt. \(Reference 4\)](#)

A poisoned data point in a shared memory store can ripple through an entire multi-agent system. One compromised input can cause agents to mis-plan, invoke unsafe tools, or embed falsehoods into collective memory without triggering traditional anomaly detection.

The threat becomes harder to manage in multi-agent environments, where multitude of models, codebases, and designs require different prompt injection defenses across different agents.

5.2 Agent Compromise

Common threats in a multi agent environment include:

- Compromise of the coordination and safeguard agents in a multiagent environment.
- In a competitive environment, one agent exploits vulnerabilities or weaknesses in other agents to gain an unfair advantage.
- Race condition in a multi agent environment.
- Misalignment of agent's goals.
- Segregation of duties of the agent environment. While one agent might have appropriate system access, the combined accesses of multiple agents might violate segregation of duties rules in place. For example, EchoLeak allows an external attacker to "read Copilot's mind" by injecting malicious commands into its context, and using a vulnerability chain to leak sensitive information to the attacker.
- Corruption or manipulation of agent objectives e.g. [AI coding tool wipes production database, fabricates 4,000 users, and lies to cover its tracks.](#) ([Reference 11](#))
- Authority amplification, where agents cite each other to justify expanded privileges.
- Supply chain compromise of agentic AI components, resulting in malicious defaults or hidden backdoors e.g. [AiXBT Token Falls 20% After AI Influencer Hacked for \\$100K in Ethereum.](#) ([Reference 8](#))

Once an agent is compromised, it can act as a malicious insider. In a multi-agent setting, even subtle goal changes can spread, justifying unsafe actions by chaining "authoritative" outputs from other agents, a dynamic that's hard to detect without behaviour-aware monitoring.

5.3 Multi-Agent Environment Exploitation

The interdependent nature of multi-agent ecosystems is exploited to bypass safeguards or disrupt operations.

- Compromise of shared infrastructure such as file storage, vector stores, or memory spaces
- Privilege escalation across agents by abusing shared tools, integrations, or orchestration layers. e.g. [Potential Attack Surfaces in Agent2Agent \(A2A\) Protocol](#). ([Reference 7](#))
- Unbounded autonomy allowing agents to operate beyond intended scope or oversight
- Unforeseen interactions between agents leading to unsafe outcomes
- Uncontrolled consumption could exhaust resources in the shared IT environment. e.g. memory, storage, token
- Physical attack of the shared IT infrastructure leading to unavailability of partial or entire environment

Multi-agent environments magnify systemic risk. A flaw in a shared vector store or orchestration layer doesn't just compromise one agent, it can hand an attacker coordinated access to every connected agent and the tools they control.

5.4 Communication Manipulation

Inter-agent communication channels are targeted to distort coordination or inject malicious influence.

- Manipulation or disruption of coordination channels resulting in unsafe or unexpected outcomes
- Malicious inter-agent influence via crafted messages, falsified state information, or injected dialogue. e.g. vulnerabilities in A2A protocol
- Vulnerabilities in communication protocols enabling spoofing, impersonation, or replay attacks. e.g. [CVE-2025-6167: python-a2a has a path traversal in the create_workflow function](#). ([Reference 6](#))
- Vulnerabilities in communication to services (e.g. MCP server) resulting in unexpected outcomes. e.g. [Asana warns MCP AI feature exposed customer data to other orgs](#). ([Reference 19](#))

Agent-to-agent communication is the nervous system of an agentic architecture. If an attacker controls the messages, they control the behaviour leading to silent coordination collapse, tool misuse, or cascading operational failures.

5.5 Identity and Privileged Access Abuse

Weaknesses in agent identity lifecycle, authentication, and authorisation allow impersonation or privilege misuse.

- Faking or impersonating an authorised agent identity.
- Replay or reuse of stale credentials or tokens.
- Persistent static identities allowing uncontrolled long-term access.
- Through compromised agent or malicious prompt, unauthorised access to data sources that is only accessible to one agent. e.g. [GitHub MCP Exploited: Accessing private repositories via MCP](#). ([Reference 10](#))

Without strong identity and privilege access controls, an attacker can operate as a “trusted” agent indefinitely. This enables unrestricted tool access, manipulation of shared context, and long-term persistence inside the agentic ecosystem.

6. Security Controls

Securing agentic AI systems requires a layered control architecture that addresses the risks of autonomous decision-making, dynamic coordination, and multi-agent interaction. Controls must operate across governance, technical, and assurance domains to ensure that autonomy is observable, bounded, and aligned with enterprise risk appetite.

The controls below are structured to map directly to the threat categories defined earlier.

Control Category	Example Measures	Principles Supported	Threats Mitigated
Governance	Role definition and accountability, agent registration, delegation governance, runtime scope enforcement, escalation pathways	Bounded autonomy, Preserve coordination trust, Observability	Agent Compromise, Multi-Agent Environment Exploitation, Identity and Privileged Access Abuse
Technical	Memory isolation, temporary identity, signed communications, toolchain attestation, trusted execution environment, real-time policy enforcement	Ephemeral identity, Bounded autonomy, Preserve coordination trust, Observability	Input Compromise, Agent Compromise, Communication Manipulation, Identity and Privileged Access Abuse
Assurance	Telemetry pipelines, runtime validation, cryptographically verifiable logs, audit overlays, behavioural drift detection, feedback loops	Observability, Preserve coordination trust, Bounded autonomy	All five threat categories

Table 4: Control categories to address threats to Agentic AI systems

6.1 Governance Controls

Establish leadership, accountability, and oversight structures to ensure agentic AI operates within defined boundaries.

- **Role definition and accountability mapping:** Define roles such as Agent Owner, Delegation Approver, and Runtime Oversight Authority, each with explicit responsibilities for tool access approval, delegation validation, and audit sign-off.
- **Agent registration and deployment pre-approval:** Require registration for all agents, including declared scope, tool access, and delegation rights, align approvals with organisational risk appetite.
- **Delegation governance and trust contracts:** Formalise inter-agent delegation rules, including permissible task types, context sharing limits, and revocation triggers, make delegation chains auditable.
- **Runtime policy scope enforcement:** Enforce execution limits based on defined role and context, ensure policies adapt to environmental changes without manual intervention.
- **Escalation pathways and decision authority:** Direct ambiguous or high-impact decisions to authorised human oversight or supervisory agents.
- **Agentic alignment:** in a multi agent environment ensure agents' goals are aligned. This can help to ensure all agents working towards the same goal, and not competing against each other and result in competitive behaviour, or collusion.
- **Segregation of duties:** in a multi agent environment ensure the combination of each agent does not breach any segregation of duties rules. Although each agent might have limited access, the accumulation of access in a multi agent environment may result in incompatible duties and access.
- **Prevent hallucination propagation:** in a multi-agent environment where the agent is tasked with finding the most optimal way to reach an objective, there is a higher risk of hallucination propagation where the ideal path is one that may contain the same bias. The design needs to be aware and include this into consideration.

6.2 Technical Controls

Enforce security boundaries at architectural and runtime layers to constrain behaviour and prevent compromise propagation.

- **Memory isolation and scoped access:** Restrict agents to session-bound memory segments, prevent unauthorised access to other agents' memory or shared knowledge without explicit authorisation.
- **Ephemeral identity constructs:** Issue short-lived, context-bound credentials per execution session, expire automatically and bind to runtime policy scopes.
- **Signed coordination channels:** Require cryptographic signing and verification for all inter-agent communications to prevent spoofing and tampering.
- **Toolchain attestation and invocation filtering:** Validate tool integrity, filter execution parameters, and block unapproved tool use.
- **Trusted execution environments (TEEs):** Execute sensitive planning and tool invocation logic in hardware-isolated environments.
- **Real-time policy enforcement:** Enforce least-privilege tool and data access, evaluate policy compliance before execution completes.
- **Input validation:** Prompt injection protection to protect individual agents, as well as other agents in a multi-agent environment, their respective LLM and its toolset.
- **Hardened agent:** ensure agents are security hardened. In a multi-agent environment this also includes the coordinating agent and the guardrail agent to ensure they are not compromised and jeopardise the integrity and availability of the agentic environment.
- **Resource limits and quotas:** enforce resource limits and/ or alert for critical computation resources. This should also include any AI related resources including inference token.
- **Secure communications:** This includes between agents (e.g. A2A) and communication to MCP services end to end.

6.3 Assurance Controls

Verify and continuously validate that governance and technical measures are effective in live environments.

- **Telemetry pipelines and coordination health monitoring:** Log all agent actions, delegations, memory changes, and communications in structured, queryable form.
- **Runtime validation and anomaly detection:** Continuously validate decisions and outputs against baseline behaviours and policy rules, trigger alerts for anomalies.
- **Cryptographically verifiable logs:** Apply tamper-evident signatures and immutable timestamps to all logs for forensic integrity.
- **Audit overlays and observability extensions:** Allow authorised observers to inspect decision paths, delegation trees, and execution flows without altering state.
- **Behavioural baselining and drift detection:** Detect gradual or abrupt deviations from expected behavioural patterns and adjust controls accordingly.
- **Feedback loops for policy refinement:** Use findings from telemetry and incident reviews to iteratively improve policies and detection rules.
- **Physical security of the computing environment:** In particular the technologies that powers the agents, its LLM and related infrastructure.

7. Target State for Secure Agentic AI

The Target Architecture translates asset categories, and threat model set out in earlier sections into a cohesive design for secure deployment of multi-agent, agentic AI systems.

This target state achieves the following goals:

- **Defend all asset categories:** Infrastructure, Orchestration, Data and Decision, and Tools with targeted controls at their most exposed points.
- **Address all threat types:** input compromise, agent compromise, multi-agent exploitation, communication manipulation, and identity/privilege abuse.
- **Scale controls with maturity:** from foundational boundaries to cryptographically verified coordination without major redesign.

7.1 Target Architecture Overview

The architecture is structured as a **layered defence model** in which each plane protects specific asset categories and directly intercepts the threats described in Section *Threat Landscape*. Controls for each layer are detailed in Section *Security Controls*. This section describes how these components work together as a complete solution:

1. **Identity & Access Plane** (*Infrastructure + Orchestration*)
Every agent, orchestrator, and tool in the system acts as a privileged identity with potential impact on business processes. Assigning ephemeral, context-bound identities reduces the attack surface and ensures that trust is never assumed indefinitely. This is critical to counter identity abuse, impersonation and privilege escalation threats. Also each AI agent is assigned individual identity to preserve non-repudiation and allow granular access control and logging.
2. **Orchestration & Policy Plane** (*Orchestration*)
In an autonomous system, orchestration logic is the primary governor of agent behaviour. Embedding policy enforcement here ensures autonomy remains bounded and that delegations occur only within approved scopes. This prevents uncontrolled task chaining, multi-agent escalation, agent compromise and multi-agent exploitation.
3. **Communication & Trust Plane** (*Infrastructure + Data and Decision*)
Multi-agent systems rely heavily on inter-agent communication. Without cryptographic validation, these channels are prime targets for manipulation.

Ensuring message authenticity and integrity at this layer helps preserve coordination trust and mitigates risks such as communication manipulation and spoofing.

4. **Memory & Knowledge Plane** (*Data and Decision*)

Shared memory is both a force multiplier and a vulnerability. Poisoned inputs or memory compromise can propagate across different agents. Isolated memory space, partitioning and validating access maintains informational integrity and prevents long-term compromise.

5. **Tooling & Integration Plane** (*Tools*)

Tools, MCP and APIs are the bridge between agentic AI decisions and real-world actions. Adequate authentication and authorisation prevents abuse, ensures alignment with policy, and blocks unintended high-impact operations.

6. **Execution & Platform Plane** (*Tools + Infrastructure*)

The execution environment is where agents and code actually run. Hardened, verifiable environments reduce the risk of environment breakout, supply chain attacks, and unauthorised code execution. Physical protection of the data centre also ensures availability and continuous operations of the AI agents and related environments.

7. **Observability & Assurance Plane** (*All*)

Without visibility into agent decisions and actions, governance is impossible. This layer ensures all key behaviours are observable, verifiable, and attributable forming the backbone of detection, investigation, and trust. This helps in mitigating threats emerging from detection, attribution, and rapid response.

8. **Lifecycle & Supply Chain Plane** (*Orchestration + Capabilities*)

Model, code, and tool integrity is not just a development concern, it is an ongoing operational requirement. Securing the lifecycle ensures that every change, from model updates to plugin deployment, maintains alignment with trust and compliance requirements and helps in mitigating Supply chain tampering, configuration drift.

Agentic AI Defense Threat Matrix

Defense Planes	Input Compromise	Agent Compromise	Multi-Agent Environment Exploitation	Communication Manipulation	Identity and Privileged Access Abuse
1. Identity & Access Plane (Infrastructure + Orchestration)		✓	✓		✓
2. Orchestration & Policy Plane (Orchestration)		✓	✓		✓
3. Communication & Trust Plane (Infrastructure + Data and Decision)	✓		✓	✓	
4. Memory & Knowledge Plane (Data and Decision)	✓	✓	✓	✓	
5. Tooling & Integration Plane (Tools)	✓	✓	✓		✓
6. Execution & Platform Plane (Tools + Infrastructure)		✓	✓		
7. Observability & Assurance Plane (All Asset Categories)	✓	✓	✓	✓	✓
8. Lifecycle & Supply Chain Plane (Orchestration + Capabilities)		✓	✓		

Diagram 3 depicting how defense can mitigate the different threat categories

7.2 Benefits of the proposed architecture

When implemented in alignment with the controls defined earlier in this paper, this pattern achieves **maximum feasible safety** for agentic AI through:

- **Layered Defence-in-Depth:** Multiple independent enforcement points protect every asset category, ensuring no single control failure leads to system compromise.
- **Runtime Policy Enforcement:** Decisions are validated in real time against organisational and contextual rules, preventing unsafe or unapproved actions before they occur.
- **Containment and Isolation:** Asset partitioning, scoped credentials, and segmented execution environments prevent escalation and lateral movement.
- **Preservation of Trust:** Cryptographically verifiable communications and immutable logging maintain coordination integrity and provide auditable evidence for oversight.
- **Progressive Capability Growth:** The maturity-aligned structure ensures that early investments in controls remain relevant and form the foundation for higher assurance levels.

By integrating identity, policy, communication, memory, tooling, execution, observability, and lifecycle security into a **single cohesive framework**, organisations can deploy agentic AI systems with confidence that autonomy will remain **bounded, observable, and trustworthy** even in complex, multi-agent environments.

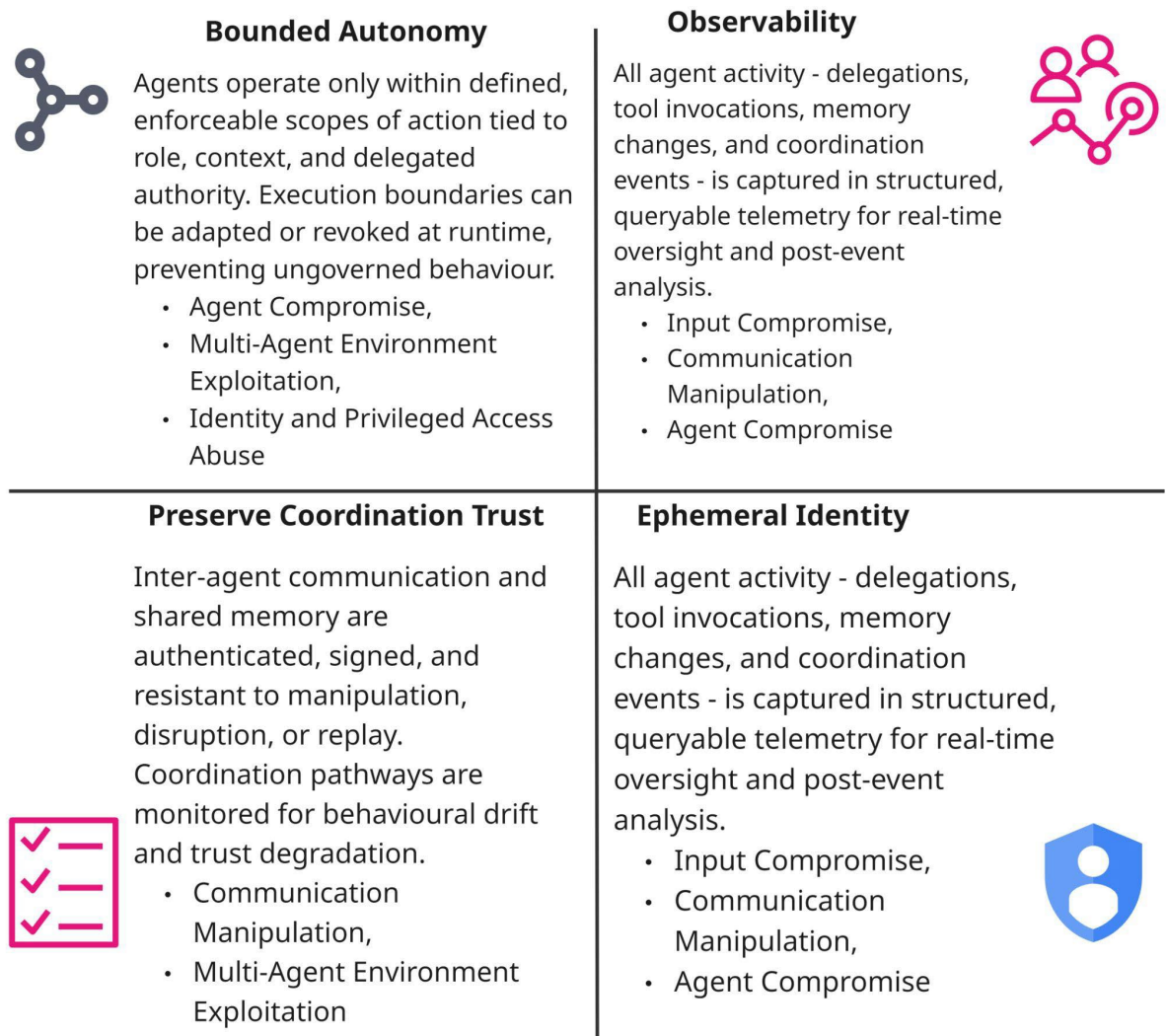


Diagram 4 depicting the four governing principles addressing emerging threats.

8. Agentic AI Security Maturity Model

The Target State describes what good looks like for secure, reliable, and governed agentic AI. The Maturity Model defines the pathway to get there.

Adopting the common CMMI model (Capability Maturity Model Integration), it sets out progressive capability levels, from unmanaged experimentation to fully verified coordination, allowing organisations to benchmark their posture and plan improvements aligned to their operational needs and risk appetite.

In all levels above the most basic, effective security is defined not just by the absence of compromise but by the presence of enforceable constraints, continuous observability, and assured coordination. Mature deployments operate within clearly bounded scopes of autonomy, governed by runtime-enforced policies, ephemeral and auditable identities, and authenticated, tamper-resistant communication channels. These are the foundations of trust in multi-agent ecosystems where decisions are distributed, actions are autonomous, and outcomes are non-deterministic.

Each level builds on the previous one by introducing stronger governance, deeper technical safeguards, and more integrated assurance. Organisations may choose to stabilise at the level that meets their business, compliance, and operational needs but all should aim to reach and sustain a posture where agentic AI behaves predictably, transparently, and within defined boundaries.

Agentic AI Security Maturity Model

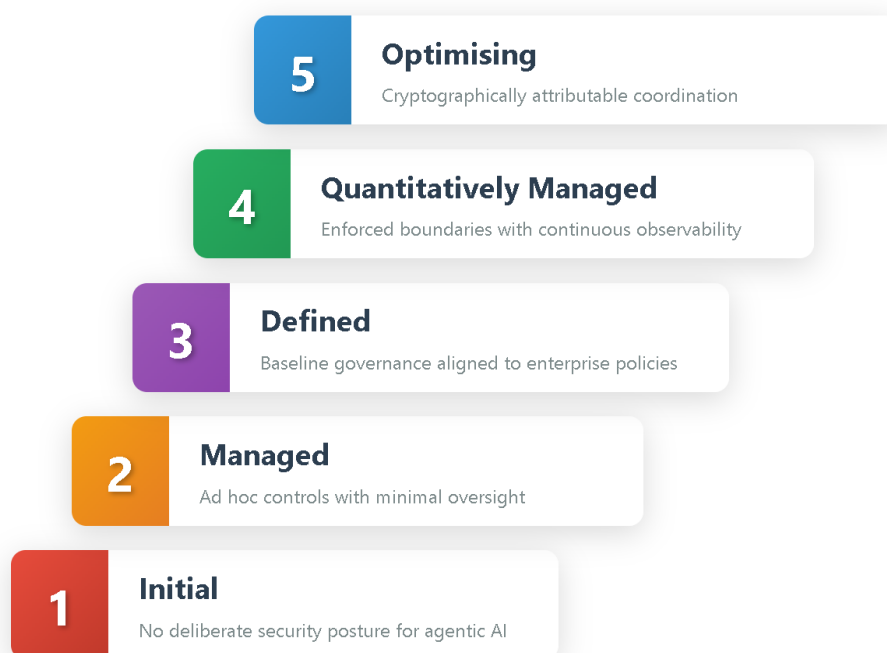


Diagram 5 Agentic AI Security Maturity Model

When considering the risks of an agentic AI tool, it is important to consider that a cascading chain of failures across a multi-agent system is a tangible threat to the organisation, and as such, an organisation must consider the scenario where in a multi agent ecosystem, one agent does not meet the minimum level of controls/compliances/governance, and interdependencies between agents may expose an organisation to heightened risk.

Similar to the standard CMMI model, the desired maturity level should align with the organisation's business nature and risk appetite. Achieving the right balance between risk and reward requires careful planning when defining the target state of the maturity model.

8.1 Level 1: Initial

Security posture for agentic AI is undeveloped. While standard enterprise controls (e.g., firewalls, access management, or logging) may exist, none are tailored to the unique risks posed by autonomous AI agents

No deliberate security posture for agentic AI. Characteristics include:

- No defined agent lifecycle or onboarding process, agents may be launched without registration
- Agents autonomy is undefined they can self-initiate, act, and coordinate without oversight
- Role configuration and tool permissions are manually assigned or inherited without verification
- Persistent identities and unconstrained access to memory or tools
- No runtime controls, policy enforcement, or agent-specific delegation limits
- Minimal or absent observability, existing logs provide no insight into agent operations

At this stage, agents are running on top of generic IT environments but outside any governance model. This creates high exposure to impersonation, misuse, and emergent failures, with limited ability to detect or recover from incidents.

8.2 Level 2: Managed

AI implementation with ad hoc controls and minimal oversight. Characteristics include:

- Undefined or unbounded scopes of autonomy
- Role configurations and tool permissions manually assigned or inherited without verification
- No formal agent registration or pre-deployment review

- Static, reused identity tokens
- Minimal or absent observability, ad hoc telemetry at best

Although basic controls exist, exploration at this level carries significant security and operational risk. Systems are highly vulnerable to impersonation, misuse, and emergent behavioural failure.

8.3 Level 3: Defined

Baseline governance and safeguards aligned to enterprise policies. Characteristics include:

- Agent registration and pre-deployment review for tool access, role definitions, and delegation scopes
- Runtime policy guards to limit tool use and memory access by role
- Escalation pathways for high-impact or ambiguous decisions routed to human oversight
- Ephemeral credentials scoped to role and session
- Basic logging and telemetry, though not cryptographically enforced or continuously monitored

Controls at this level establish structured but static controls, enabling oversight and risk containment. This level lacks enforcement depth, adaptive telemetry, and systemic trust in coordination.

8.4 Level 4: Quantitatively Managed

Enforced boundaries and continuous system-level observability. Characteristics include:

- Runtime evaluation of delegation, execution, and toolchain interaction policies
- Tool invocation filtering and output sanitisation via brokered execution
- Memory isolation and scoped access to shared or long-term stores
- Cryptographically verifiable, immutable logs
- Real-time telemetry integrated into behavioural baselining and anomaly detection

At this level, agentic systems operate under enforceable constraints. Actions are observable, replayable, and validated automatically. Drift from expected behaviour can be detected and acted on in near real-time.

8.5 Level 5: Optimising

All coordination, execution, and decision-making are cryptographically attributable, policy-compliant, and continuously validated. Characteristics include:

- Signed, attested inter-agent communication with behavioural traceability
- Distributed trust enforcement through delegation contracts and runtime attestation
- Dynamic revocation and replacement of roles, identities, or capabilities based on risk signals
- Real-time observability overlays showing plan evolution, execution state, and decision lineage
- Automated feedback loops linking telemetry to policy refinement, retraining, or reconfiguration

This is the maturity apex for agentic AI. Systems can be trusted to operate autonomously in critical domains with continuous governance, verifiable execution, and resilient coordination. Organisations at this level can demonstrably control, audit, and adapt agentic systems even in adversarial or uncertain conditions.

8.6 Measurable Metrics

Metrics are useful for assessing progress toward a specific maturity level. The examples below illustrate possible measures; however, organizations may need to recalibrate these metrics to align with their unique context or define alternative ones that better reflect their business objectives.

Maturity	Examples of Measurable Metrics
Level 1 Initial	• No metrics
Level 2 Managed	• % of deployed agents with any form of registration (target: >50%) • % of agent actions logged (target: >25%)
Level 3 Defined	• % of deployed agents registered (target: 100%) • % of high-impact actions routed for human review (target: 100%) • Credential expiry within defined policy (e.g., ≤24 hours)

Maturity	Examples of Measurable Metrics
Level 4 Quantitatively Managed	• % of agent messages cryptographically signed (target: $\geq 95\%$) • % of agents operating with isolated memory spaces (target: 100%) • Mean time to remediate (MTTR) for detected anomalies (target: ≤ 30 mins)
Level 5 Optimising	• % of coordination events with attestation (target: 100%) • % of revocations completed within policy SLA (target: $\geq 95\%$) • Mean time to policy update from anomaly detection (target: ≤ 24 hours)

Table 5: Examples of measurable metrics

9. Operationalising the Framework

Operationalising this framework means applying the recommended controls where they can have the greatest impact, sequencing their adoption in a way that delivers early risk reduction, and ensuring they function together as an integrated defence.

Agentic AI changes state dynamically, delegates autonomously, and coordinates in real time. These traits make static reviews and pre-deployment checks insufficient on their own. Security must be embedded into live operations, with mechanisms that respond to changes as they happen.

The table below summarises each asset category with its relevant threat categories and the controls.

Asset Category	Relevant Threats	Relevant Controls	Principles Supported
Infrastructure	• Multi-Agent Environment Exploitation • Communication Manipulation	• Governance: Delegation governance, Agent registration, Role definition and accountability, Escalation pathways • Technical: Signed coordination channels, Ephemeral, context-bound identities	Preserve coordination trust, Observability, Ephemeral identity

Asset Category	Relevant Threats	Relevant Controls	Principles Supported
	Identity and Privileged Access Abuse	Assurance: Communication monitoring, Identity usage monitoring, Immutable logs	
Orchestration	- Agent Compromise - Multi-Agent Environment Exploitation	Governance: Role definition and accountability, Runtime policy enforcement Technical: Real-time policy enforcement, Least-privilege enforcement Assurance: Behavioural drift detection, Coordination health telemetry	Bounded autonomy, Observability, Preserve coordination trust
Data and Decision	- Input Compromise - Agent Compromise	Governance: Delegation governance, Escalation pathways Technical: Memory isolation and scoped access, Toolchain attestation and invocation filtering Assurance: Structured telemetry, Input anomaly detection, Audit overlays	Observability, Preserve coordination trust
Tools	- Input Compromise - Agent Compromise - Multi-Agent Environment Exploitation	Governance: Runtime policy enforcement, Escalation pathways Technical: Toolchain attestation and invocation filtering, Real-time policy enforcement Assurance: Structured telemetry, Tool usage anomaly detection	Bounded autonomy, Ephemeral identity, Preserve coordination trust

Table 6: Mapping assets, threats, controls and principles

To transition the security framework from conceptual design to operational reality, organisations must focus on embedding controls, assigning clear ownership, and reinforcing system-level observability. The following sections outline the foundational steps required to establish a secure, scalable, and resilient agentic AI environment.

9.1 Immediate Implementation Priorities

To establish early momentum and build foundational assurance, security leaders should prioritise a focused set of actions that deliver immediate visibility, enforce basic guardrails, and prepare the environment for progressive control deployment.

1. **Inventory** all agentic AI deployments and classify them against the in-scope system traits defined earlier.
2. **Assign ownership** across governance, technical enforcement, and assurance - ensure responsibilities are clear and cross-functional.
3. **Deploy an observability pipeline** for all agents, capturing delegations, decisions, and tool calls - even before other controls are in place.
4. **Pilot ephemeral identity and signed communication** in one high-impact use case to validate feasibility and integration points.
5. **Plan maturity progression** using the model in the next section and set quarterly adoption targets.

9.2 Secure High-Value Integration Points

In practice, the fastest gains come from embedding controls at a small number of high-value integration points where multiple asset categories and threat vectors intersect:

- **Orchestration layers:** Secure agent lifecycle, task delegation, and policy enforcement, issue ephemeral identities, capture telemetry at the coordination layer.
- **Tool brokers and invocation gateways:** Validate parameters, enforce role- and context-based access, and fail closed on unauthorised execution.
- **Shared memory systems:** Scope read/write permissions, validate content provenance, detect and quarantine anomalous entries before they propagate.
- **Inter-agent communication channels:** Sign and authenticate messages, enforce role-bound communication rules, and detect protocol anomalies.

9.3 Anticipate and Address Key Challenges

Implementing these measures means working with both technical and organisational realities:

- **Fast-changing codebases:** Integrate agent registration, policy validation, and automated coordination tests into CI/CD.
- **Distributed or federated topologies:** Carry enforcement with the agent using signed configurations and embedded policy interpreters.

- **Credential lifecycle:** Automate issuance, expiry, and rotation, bind credentials to runtime role and context.
- **Governance integration:** Connect runtime telemetry directly to governance structures, escalation processes, and compliance checks.
- **Real-time enforcement:** Enforce policy at the point of execution, detect and remediate behavioural drift before it cascades.

9.4 Agree on Cross-Functional Responsibilities

Success depends on shared responsibility:

- **AI Engineering:** Embed enforcement hooks and telemetry capture into orchestration, brokers, and communication layers.
- **Security Architecture:** Define trust boundaries, control breakpoints, and identity flows.
- **Operations:** Monitor live activity, respond to incidents, and manage escalation.
- **Risk and Compliance:** Validate that controls and telemetry align with governance and regulatory requirements.

10. Conclusion and Strategic Imperatives

Securing agentic AI is not optional. As these systems gain autonomy and operate across shared execution pathways, the risks are amplified: compromised inputs, corrupted agents, manipulated coordination, and abused identities can trigger cascading failures at speed and scale. Without embedded safeguards, the attack surface will quickly exceed the organisation's ability to govern it.

As deployments scale, delegation chains will lengthen, cross-boundary coordination will increase, and trust models will fragment. Without cryptographically enforceable scopes, identity-bound policy contracts, and embedded oversight, the provenance of decisions and accountability for outcomes will become difficult to verify or control. The fragility of trust chains will only intensify unless addressed through deliberate design.

Effective protection demands governance, technical, and assurance measures operating as a unified architecture, embedded where they have maximum effect: orchestration layers, tool brokers, shared memory systems, and inter-agent communication channels. Security must be designed into the coordination layer itself shaping how agents plan, delegate, and negotiate rather than bolted on at the edges. In this role, security becomes a proactive enabler of safe autonomy, not just a reactive constraint.

Security is a shared responsibility across engineering, security architecture, operations, and governance. It must be treated as a living capability that evolves with the systems it protects.

Recommended strategic actions include:

- Focus on real-time observability and policy enforcement
- Replace static credentials with ephemeral, context-bound identities
- Enforce scope limits on tools, memory, and delegation
- Sign and attest all inter-agent communication
- Continuously feed telemetry into control refinement and threat model updates

Organisations that act now - embedding coordination-layer security, bounded autonomy, and identity ephemerality - will be positioned to scale agentic AI with confidence, resilience, and accountability. Early adopters who make these principles design-time requirements will capture the benefits of autonomous, distributed intelligence without inheriting avoidable exposure.

Glossary

Agentic AI - AI systems composed of single or multiple autonomous agents that coordinate, delegate, and adapt behaviour dynamically to achieve defined objectives.

Autonomous Agent - An AI component capable of independent decision-making and task execution without constant human oversight.

Behavioural Drift Detection - Monitoring for deviations from expected agent behaviour patterns to identify anomalies or compromise.

Bounded Autonomy - Restricting agents to operate within defined, enforceable scopes tied to their role and context, with the ability to revoke or adapt boundaries at runtime.

Delegation Governance - Formal rules and controls governing how agents delegate tasks, share context, and escalate decisions.

Ephemeral Identity - Short-lived credentials and privileges issued for specific sessions or contexts, automatically expiring to prevent persistence and lateral movement.

Identity Lifecycle Management - Processes for issuing, rotating, and revoking agent identities and credentials to prevent impersonation or privilege abuse.

Model Context Protocol (MCP) - A protocol enabling agents to interact with external tools and services dynamically, often used for context sharing and tool invocation.

Multi-Agent System - An environment where multiple agents collaborate, negotiate, and share context to achieve common or distributed goals.

Observability - The principle of capturing all agent actions, decisions, and coordination events in structured telemetry for real-time oversight and post-event analysis.

Orchestration Layer - The decision-making and coordination component that governs agent behaviour, task distribution, and policy enforcement.

Preserve Coordination Trust - Ensuring inter-agent communication and shared memory remain authenticated, verified, and resistant to manipulation or replay attacks.

Prompt Injection - A security attack where malicious inputs manipulate an agent's reasoning or bypass guardrails, leading to unsafe actions.

Retrieval Augmented Generation (RAG) - A technique where AI agents retrieve external data to enhance reasoning and decision-making during execution.

Security Maturity Model - A staged framework (Initial → Managed → Defined → Quantitatively Managed → Optimising) for progressively improving security posture in agentic AI deployments.

Shared Memory - A common repository where agents read and write data for collaborative decision-making or state persistence.

Telemetry - Structured, queryable logs capturing agent actions, delegations, and communications for monitoring and audit purposes.

Threat Categories - Five major risk areas for Agentic AI: Input Compromise, Agent Compromise, Multi-Agent Exploitation, Communication Manipulation, and Identity/Privilege Abuse.

Trusted Execution Environment (TEE) - A hardware-isolated environment that secures sensitive planning and execution logic against compromise.

References

1. Aim Labs | Echoleak M365. (2025). Aim.security. <https://www.aim.security/lp/aim-labs-echoleak-m365>
2. Agentic AI Threat Modeling Framework: MAESTRO | CSA. (2025). Cloudsecurityalliance.org. <https://cloudsecurityalliance.org/blog/2025/02/06/agentic-ai-threat-modeling-framework-maestro>
3. Beware of the woozle effect: Exploring and mitigating hallucination propagation in Multi-Agent debate. (n.d.). OpenReview. <https://openreview.net/forum?id=wKTnNykfTH>
4. ContentKeeper Content Filtering. (2025). Upworthy.com. <https://www.upworthy.com/prankster-tricks-a-gm-dealership-chatbot-to-sell-him-a-76000-chevy-tahoe-for-ex1>
5. Cloudflare (2025). Build and deploy Remote Model Context Protocol (MCP) servers to Cloudflare <https://blog.cloudflare.com/remote-model-context-protocol-servers-mcp/>
6. CVE-2025-6167: python-a2a has a path traversal in the create_workflow function | CVE Database | Miggo. (2025). Miggo.io. <https://www.miggo.io/vulnerability-database/cve/CVE-2025-6167>
7. Done, C. (2025). Potential Attack Surfaces in Agent2Agent (A2A) Protocol. Keysight.com. <https://www.keysight.com/blogs/en/tech/nwvs/2025/05/28/potential-attack-surfaces-in-a2a>
8. Hitchcock, L. (2025, March 18). AiXBT Token Falls 20% After AI Influencer Hacked for \$100K in Ethereum. Decrypt. <https://decrypt.co/310510/aixbt-ai-influencer-hacked-100k-ethereum>
9. ISACA. (2019). CMMI Institute - CMMI Levels of Capability and Performance. Cmmiinstitute.com. <https://cmmiinstitute.com/learning/appraisals/levels>
10. Marco MilantaLuca Beurer-Kellner. (2025, May 26). GitHub MCP Exploited: Accessing private repositories via MCP. Invariantlabs.ai. <https://invariantlabs.ai/blog/mcp-github-vulnerability>
11. Okunytė, P. (2025, July 21). AI coding tool wipes production database, fabricates 4,000 users, and lies to cover its tracks. Cybernews. <https://cybernews.com/ai-news/replit-ai-vive-code-rogue/>
12. OWASP (2025) Agentic AI - Threats and Mitigations <https://genai.owasp.org/resource/agentic-ai-threats-and-mitigations/>

13. OWASP Gen AI Project Editor. (2025, June 10). Multi-Agent system Threat Modeling Guide v1.0. OWASP Gen AI Security Project.
<https://genai.owasp.org/resource/multi-agent-system-threat-modeling-guide-v1-0/>
14. OWASP LLM Project Admin. (2025, February 17). Agentic AI - Threats and Mitigations - OWASP Top 10 for LLM & Generative AI Security. OWASP Top 10 for LLM & Generative AI Security. <https://genai.owasp.org/resource/agentic-ai-threats-and-mitigations/>
15. OWASP LLM Project Admin. (2024, November 18). OWASP Top 10: LLM & Generative AI Security Risks. OWASP Top 10 for LLM & Generative AI Security. <https://genai.owasp.org/>
16. Sestito, K. (2025, April 24). Novel Universal Bypass for All Major LLMs. HiddenLayer | Security for AI. <https://hiddenlayer.com/innovation-hub/novel-universal-bypass-for-all-major-llms/>
17. Threat Modeling OpenAI's Responses API with MAESTRO | CSA. (2025). Cloudsecurityalliance.org. <https://cloudsecurityalliance.org/blog/2025/03/24/threat-modeling-openai-s-responses-api-with-the-maestro-framework>
18. Top AI Security Incidents (2025 Edition) | Adversa AI. (2025, July 7). Adversa AI | Trusted AI Security. <https://adversa.ai/top-ai-security-incidents-report-2025-edition/>
19. Toulas, B. (2025, June 18). Asana warns MCP AI feature exposed customer data to other orgs. BleepingComputer.
<https://www.bleepingcomputer.com/news/security/asana-warns-mcp-ai-feature-exposed-customer-data-to-other-orgs/>
20. U.S. Department of Commerce, National Institute of Standards and Technology. (2023). *Artificial Intelligence Risk Management Framework (AI RMF 1.0)* (NIST Special Publication No. NIST.AI.100-1). <https://doi.org/10.6028/NIST.AI.100-1>